

INSTITUTO POLITÉCNICO NACIONAL
ESCUELA SUPERIOR DE CÓMPUTO
Ingeniería en Sistemas Computacionales — Semestre VI

PRÁCTICA No. 2 — “Sistema Operativo Windows: Controles de Seguridad”

Unidad I: Seguridad Ofensiva

Guía de Hardening de Windows 11 Modernizada — Benchmarks, Políticas de Grupo, Defender y Ejercicios Prácticos
Basada en investigación actualizada a febrero 2026

Nombre del alumno:	
Número de boleta:	
Grupo:	
Fecha:	

INTRODUCCIÓN

En Windows 11 Credential Guard y HVCI ahora están habilitados por defecto, BitLocker recibe aceleración por hardware a nivel de silicio, Smart App Control permite activarse y desactivarse sin reinstalar, Sysmon se integra nativamente al sistema operativo, y las APIs de criptografía post-cuántica están disponibles para proteger datos contra amenazas futuras.

El panorama de seguridad de Windows cambió drásticamente: el CIS Benchmark alcanzó la versión 4.0.0 para Windows 11 Enterprise, Microsoft publica Security Baselines para cada versión semestral (22H2 hasta 25H2), las reglas ASR (Attack Surface Reduction) se convirtieron en el mecanismo principal anti-malware junto con Defender, y Zero Trust DNS junto con Wi-Fi 7 Enterprise refuerzan la seguridad de red. Lo que sigue cubre cada dimensión que un estudiante necesita — desde marcos de cumplimiento y políticas de grupo hasta seguridad basada en virtualización y ejercicios prácticos.

1. BENCHMARKS CIS PARA WINDOWS 11 Y WINDOWS SERVER 2025

El Center for Internet Security (CIS) mantiene los benchmarks de referencia para hardening de Windows. Las versiones actuales reflejan el ecosistema Windows 11 25H2 y Windows Server 2025:

Benchmark	Versión	Detalle notable
Windows 11 Enterprise	v4.0.0 (marzo 2025)	27 controles nuevos; soporte 24H2/25H2; perfiles L1, L2, BitLocker y STIG
Windows 11 Intune	v4.0.0 (abril 2025)	Políticas MDM; 26 controles actualizados, 14 eliminados
Windows 11 Stand-alone	v3.0.0	Para equipos no unidos a dominio; perfiles L1, L2, BitLocker

Windows Server 2025	v1.0.0	Nuevo; perfiles NGWS (Next Gen Windows Security)
Security Baseline 2025	v2602 (feb 2026)	10 nuevas GPOs; auditoría NTLM, hardening SMB, sudo deshabilitado

El benchmark CIS Windows 11 Enterprise v4.0.0 contiene cientos de recomendaciones organizadas en categorías principales: Account Policies (contraseñas, bloqueo de cuentas, Kerberos), Local Policies (auditoría, derechos de usuario, opciones de seguridad), Event Log, Restricted Groups, System Services, Registry, File System, y Administrative Templates (incluyendo más de 20 subcategorías para componentes como BitLocker, Defender, Edge, Windows Update, y PowerShell).

Los perfiles del benchmark incluyen: Nivel 1 (L1, seguridad práctica con mínimo impacto en usabilidad), Nivel 2 (L2, controles estrictos para entornos de alta seguridad), BitLocker (BL, complemento específico para cifrado de disco), y el nuevo perfil NGWS (Next Generation Windows Security) en Server 2025 que mapea a los requisitos más avanzados de Microsoft.

Microsoft publica el Security Compliance Toolkit 1.0 con GPO backups descargables para cada versión de Windows. El Security Baseline más reciente para Windows Server 2025 (v2602, febrero 2026) añadió 10 nuevas configuraciones de Group Policy incluyendo: tres políticas de auditoría NTLM (Restrict NTLM: Audit Incoming/Outgoing/Domain), deshabilitación del comando sudo, validación de claves ROCA-vulnerables en Windows Hello for Business, y deshabilitación de IE11 vía COM. También incluye recomendaciones para hardening SMB contra ataques de relay (firma SMB obligatoria y Extended Protection for Authentication).

Para automatización de auditoría, el proyecto HardeningKitty (PowerShell de código abierto) soporta benchmarks CIS, Microsoft Security Baselines, DoD STIG y BSI SiSyPHuS, leyendo configuraciones del registro y otros módulos del sistema para evaluar el nivel de hardening contra listas predefinidas de hallazgos.

2. SEGURIDAD BASADA EN VIRTUALIZACIÓN (VBS): LA BASE DE WINDOWS 11

La Seguridad Basada en Virtualización (VBS) es el pilar fundamental de la arquitectura de seguridad de Windows 11. VBS utiliza el hipervisor de Windows para crear un entorno virtual aislado que se convierte en la raíz de confianza del sistema operativo, asumiendo que el kernel puede ser comprometido. Desde Windows 11 22H2 y Windows Server 2025, VBS y sus componentes dependientes están habilitados por defecto en dispositivos que cumplen los requisitos de hardware.

Credential Guard (habilitado por defecto desde 22H2)

Credential Guard protege contra ataques de robo de credenciales (Pass-the-Hash, Pass-the-Ticket) aislando los hashes de contraseñas NTLM, Ticket Granting Tickets de Kerberos y credenciales almacenadas por aplicaciones dentro de un contenedor VBS al que ni siquiera el kernel de Windows tiene acceso directo. Desde Windows 11 22H2, Credential Guard se habilita por defecto (sin UEFI Lock) en dispositivos Enterprise y Education que cumplen requisitos de hardware. Los administradores pueden deshabilitarlo remotamente vía Group Policy, Intune o MDM. Es importante notar que Credential Guard bloquea NTLMv1 y MS-CHAP, lo que puede afectar VPN y redes 802.1x que dependan de protocolos inseguros.

Hypervisor-Protected Code Integrity (HVCI / Memory Integrity)

HVCI, también conocido como Memory Integrity o Integridad de Memoria, ejecuta la verificación de integridad de código en modo kernel dentro del entorno aislado de VBS. Esto impide que malware inyecte código malicioso en procesos del kernel, incluso si el atacante tiene privilegios de administrador. HVCI está habilitado por defecto en Windows 11 22H2+. En la interfaz se encuentra como Configuración > Privacidad y seguridad > Seguridad de Windows > Seguridad del dispositivo > Aislamiento del núcleo > Integridad de memoria.

Protección LSA (Local Security Authority)

La protección de LSA configura el proceso LSASS (Local Security Authority Subsystem Service) como un proceso protegido (PPL — Protected Process Light), bloqueando la inyección de código no firmado y dificultando enormemente herramientas como Mimikatz. Se habilita vía Group Policy: Computer Configuration > Administrative Templates > System > Local Security Authority > Configure LSASS to run as a protected process = Enabled with UEFI Lock (en hardware moderno). El Security Baseline de Microsoft recomienda esta configuración con prioridad alta.

3. MICROSOFT DEFENDER Y REGLAS ASR (ATTACK SURFACE REDUCTION)

Microsoft Defender Antivirus en 2026

Microsoft Defender Antivirus ha evolucionado de un antivirus básico a una plataforma de protección endpoint completa. Las capacidades actuales incluyen: protección en tiempo real con machine learning local y en la nube, protección contra PUA (Potentially Unwanted Applications) en modo Block, Cloud-delivered protection con veredictos rápidos para malware nuevo, protección de red (Network Protection) que bloquea conexiones a dominios maliciosos, y Controlled Folder Access (Acceso Controlado a Carpetas) diseñado específicamente contra ransomware.

La función Controlled Folder Access monitorea los cambios que las aplicaciones realizan en carpetas protegidas (Documentos, Escritorio, Imágenes, etc.). Solo las aplicaciones de confianza pueden modificar archivos en estas carpetas — si una aplicación desconocida intenta escribir, se bloquea y se genera una alerta. Esta es la defensa más directa contra ransomware integrada en el sistema operativo.

Reglas ASR: el control más subestimado de Defender

Las reglas de Reducción de Superficie de Ataque (ASR) son controles que restringen comportamientos específicos que el malware explota comúnmente, pero que las aplicaciones legítimas rara vez utilizan. A diferencia del antivirus tradicional que busca firmas de malware, las reglas ASR bloquean las técnicas que el malware usa. Requieren Microsoft Defender Antivirus en modo activo y soportan tres estados de configuración: Block (bloqueo activo), Audit (registra sin bloquear, para evaluación de impacto), y Warn (muestra advertencia al usuario, permitiendo bypass temporal de 24 horas).

Microsoft clasifica las reglas ASR en dos categorías principales:

Reglas de Protección Estándar (Standard Protection — habilitar siempre)

Reglas adicionales recomendadas

La estrategia de despliegue recomendada sigue un enfoque basado en confianza: iniciar todas las reglas en modo Audit para visualizar impacto, mover a modo Warn para educar usuarios, y finalmente aplicar modo Block cuando las exclusiones estén afinadas. Los eventos ASR se registran en Event Viewer > Applications and Services Logs > Microsoft > Windows > Windows Defender > Operational, con Event ID 1121 (Block) y 1122 (Audit). En PowerShell se configuran con `Add-MpPreference -AttackSurfaceReductionRules_Ids <GUID> -AttackSurfaceReductionRules_Actions <Estado>`.

4. BITLOCKER: CIFRADO DE DISCO CON ACELERACIÓN POR HARDWARE

BitLocker es la solución de cifrado de disco completo integrada en Windows, diseñada para proteger datos en reposo contra acceso físico no autorizado. En Windows 11 25H2, BitLocker recibió la mejora más significativa de su historia: aceleración por hardware a nivel de silicio.

BitLocker acelerado por hardware (nuevo en 2025-2026)

La nueva funcionalidad de hardware-accelerated BitLocker descarga las operaciones criptográficas del CPU principal a un motor criptográfico dedicado integrado en los procesadores modernos (SoC). Esto duplica las velocidades de lectura y escritura secuencial comparado con el cifrado por software: las pruebas de Microsoft con CrystalDiskMark muestran lecturas de ~1,632 MB/s (software) contra ~3,746 MB/s (hardware), y escrituras de ~1,513 MB/s contra ~3,530 MB/s. Las claves de cifrado se envuelven y aíslan a nivel de silicio, minimizando la exposición a vulnerabilidades de CPU y memoria. El soporte inicial llega con procesadores Intel Core Ultra Series 3 (Panther Lake) en primavera 2026. Se puede verificar con `manage-bde -status`, que mostrará "Hardware accelerated" en el método de cifrado.

Configuración recomendada de BitLocker

La configuración del CIS Benchmark recomienda: requerir TPM (Trusted Platform Module) para el almacenamiento seguro de claves, usar cifrado XTS-AES-256 para máxima seguridad, deshabilitar claves en claro (clear key), respaldar claves de recuperación en Active Directory DS o Entra ID, y considerar un PIN de pre-arranque para roles de alto riesgo. La política de grupo se configura en: Computer Configuration > Administrative Templates > Windows Components > BitLocker Drive Encryption.

Adicionalmente, Windows 11 introduce Personal Data Encryption (PDE), una capa de cifrado complementaria a BitLocker que protege archivos específicos del usuario mientras este no ha iniciado sesión. PDE vincula las claves de cifrado a las credenciales passwordless de Windows Hello for Business, proporcionando protección granular a nivel de archivo.

5. SMART APP CONTROL Y APP CONTROL FOR BUSINESS

Smart App Control (SAC)

Smart App Control es una funcionalidad de seguridad de Windows 11 que bloquea la ejecución de aplicaciones no confiables utilizando firma de código e inteligencia artificial basada en la nube

de Microsoft para evaluar si un proceso es seguro. Hasta 2025, activar SAC requería una reinstalación limpia del sistema operativo para desactivarla — a partir de la actualización de febrero 2026 (KB5077181), Smart App Control puede activarse y desactivarse libremente desde Windows Security > App & Browser Control > Smart App Control settings sin necesidad de reinstalar, lo que lo hace finalmente práctico para uso cotidiano.

App Control for Business (antes WDAC)

Para entornos empresariales, App Control for Business (anteriormente Windows Defender Application Control — WDAC) proporciona control de aplicaciones a nivel de política que aplica a todo el equipo y afecta a todos los usuarios. A diferencia de AppLocker que opera a nivel de usuario, App Control for Business se diseñó como característica de seguridad bajo los criterios del Microsoft Security Response Center (MSRC). Las políticas pueden desplegarse vía Intune, Configuration Manager, Group Policy o PowerShell, y permiten definir listas de permitidos/bloqueados basadas en editor (publisher), hash de archivo, ruta, o atributos de Intelligent Security Graph de Microsoft.

Enhanced Phishing Protection

Windows 11 incluye protección anti-phishing integrada directamente en el sistema operativo — la primera plataforma en hacerlo. SmartScreen Enhanced Phishing Protection emite advertencias cuando el usuario intenta ingresar credenciales de Microsoft en una aplicación maliciosa o un sitio web comprometido. Se configura en: Computer Configuration > Administrative Templates > Windows Components > SmartScreen > Enabled: Warn and prevent bypass.

6. LAS 20 CONFIGURACIONES DE GROUP POLICY MÁS CRÍTICAS

Microsoft proporciona más de 3,000 configuraciones de Group Policy solo para Windows 11. Las siguientes 20 representan las configuraciones de mayor impacto en seguridad, organizadas en tres olas de despliegue:

Ola 1: Proteger credenciales

Ola 2: Bloquear cadenas de ataque comunes

Ola 3: Hardenizar superficie de red

Se recomienda crear un GPO de piloto ("Win11-Hardening-Pilot") en una OU de prueba, validar con gpresult /h y Event Viewer, documentar excepciones con propietarios y fechas de expiración, y expandir gradualmente. Para equipos standalone, el Local Group Policy Editor (gpedit.msc) permite configurar estas mismas políticas localmente.

7. WINDOWS FIREWALL CON SEGURIDAD AVANZADA

Windows Defender Firewall with Advanced Security opera en tres perfiles de red: Domain (red corporativa con Active Directory), Private (redes domésticas o de confianza), y Public (redes

públicas no confiables como cafés o aeropuertos). Cada perfil tiene configuración independiente de reglas de entrada/salida, logging, y comportamiento predeterminado.

La configuración recomendada del CIS Benchmark para los tres perfiles establece: Firewall state = On, Inbound connections = Block, Outbound connections = Allow, Display a notification = No (perfil Public), Logging size limit = 16,384 KB, Log dropped packets = Yes, y Log successful connections = Yes. Las reglas personalizadas deben seguir el principio de mínimo privilegio: bloquear todo por defecto y permitir solo el tráfico explícitamente necesario.

Para acceder al firewall avanzado: wf.msc o Windows Security > Firewall & network protection > Advanced settings. Las reglas se pueden exportar/importar vía netsh advfirewall export/import y automatizar con PowerShell usando New-NetFirewallRule. En entornos empresariales, Windows Firewall se gestiona centralmente mediante Group Policy o Microsoft Intune.

8. SYSMON NATIVO Y AUDITORÍA DE EVENTOS DE WINDOWS

Sysmon integrado nativamente (nuevo febrero 2026)

System Monitor (Sysmon), que durante más de una década fue una herramienta separada del paquete Sysinternals, se integra nativamente en Windows 11 a partir de febrero 2026 (Build 26200.7922, KB5077241). Esta es posiblemente la mejora más significativa para la detección de amenazas en Windows en años recientes. Sysmon proporciona telemetría de alta fidelidad que va mucho más allá de los logs estándar de Windows, capturando: creación de procesos con línea de comandos completa (Event ID 1), conexiones de red (Event ID 3), acceso a procesos como lectura de LSASS (Event ID 8), creación de archivos (Event ID 11), process tampering (Event ID 25), y eventos WMI de persistencia (Event IDs 20/21).

Para habilitar Sysmon nativo: Settings > System > Optional features > More Windows features > activar Sysmon, o desde PowerShell: `Dism /Online /Enable-Feature /FeatureName:Sysmon`. Luego ejecutar `Sysmon -i` para instalar con configuración por defecto, o `Sysmon -i config.xml` para aplicar un archivo de configuración personalizado que filtre los eventos deseados. Los eventos se escriben en Applications and Services Logs > Microsoft > Windows > Sysmon > Operational. Importante: si existe una instalación previa de Sysmon (descargada de Sysinternals), debe desinstalarse primero.

Advanced Audit Policy Configuration

Las políticas de auditoría avanzada de Windows permiten control granular sobre qué eventos se registran. Las categorías críticas para seguridad incluyen: Account Logon (intentos de autenticación), Logon/Logoff (inicio y cierre de sesión), Object Access (acceso a archivos y registro), Policy Change (cambios en políticas de seguridad), Privilege Use (uso de privilegios elevados), System (eventos del sistema como arranque y apagado), y Detailed Tracking (creación/terminación de procesos). Se configuran en: Computer Configuration > Windows Settings > Security Settings > Advanced Audit Policy Configuration.

Zero Trust DNS (próximamente)

Microsoft anunció Zero Trust DNS para Windows 11, que fuerza la resolución de nombres a través de servidores DNS aprobados con cifrado, bloqueando tráfico DNS no autorizado. Combinado con DNS over HTTPS (DoH, ya disponible en Settings > Network & Internet > Wi-Fi > DNS server assignment > Encrypted only), proporciona protección contra envenenamiento de DNS y exfiltración de datos vía consultas DNS.

9. WINDOWS SANDBOX, PASSKEYS Y CRIPTOGRAFÍA POST-CUÁNTICA

Windows Sandbox

Windows Sandbox proporciona un entorno de escritorio ligero y aislado para ejecutar aplicaciones no confiables de forma segura. Utiliza virtualización basada en hardware para crear un kernel separado completamente aislado del host. Al cerrar Windows Sandbox, todo el software, archivos y estado se eliminan permanentemente. Se habilita desde: Settings > Apps > Optional Features > More Windows features > Windows Sandbox, y requiere Windows 11 Pro o Enterprise con virtualización habilitada en BIOS/UEFI.

Passkeys y Windows Hello

Windows 11 en 2026 impulsa activamente la transición de contraseñas a passkeys. La integración del administrador de passkeys con Windows Hello alcanzó disponibilidad general, permitiendo elegir entre Microsoft Password Manager en Edge, 1Password, Bitwarden y otros como administradores preferidos. A partir de la actualización de febrero 2026, Windows Hello Enhanced Sign-in Security (ESS) soporta sensores de huella digital externos además de los integrados, extendiendo autenticación biométrica segura a PCs de escritorio. Las passkeys basadas en FIDO2 almacenan la clave privada en el dispositivo físico, eliminando el riesgo de robo de credenciales por phishing.

APIs de Criptografía Post-Cuántica (PQC)

Windows 11 ahora ofrece APIs de criptografía post-cuántica (PQC) que implementan algoritmos diseñados para resistir ataques de computadoras cuánticas que podrían romper la criptografía tradicional RSA y ECC. Estas APIs permiten a las organizaciones comenzar la migración a cifrado resistente a computación cuántica ahora, antes de que la amenaza se materialice (estimada para mediados de los 2030s). Esto complementa la transición a SSH post-cuántico vista en OpenSSH 10.0 (Práctica No. 1) y representa la estrategia de Microsoft contra la amenaza "store now, decrypt later".

10. SECURE BOOT, TPM 2.0 Y LA EXPIRACIÓN DE CERTIFICADOS 2026

Windows 11 requiere TPM 2.0 y Secure Boot como requisitos mínimos de hardware, estableciendo una cadena de confianza desde el firmware hasta el sistema operativo. Secure Boot verifica que cada componente cargado durante el arranque (firmware UEFI, bootloader, kernel) esté firmado digitalmente, previniendo rootkits y bootkits que se cargarían antes que el sistema operativo.

Alerta crítica para 2026: Los certificados de Secure Boot originales de 2011 utilizados por la mayoría de dispositivos Windows expiran en junio de 2026. Si no se actualizan antes de esa fecha, los dispositivos afectados podrían perder la capacidad de arrancar de forma segura. Microsoft comenzó a distribuir certificados actualizados gradualmente a partir de enero 2026, verificándolos en dispositivos que demuestren señales suficientes de actualizaciones exitosas. Los administradores deben revisar la guía de Microsoft "Windows Secure Boot certificate expiration and CA updates" y tomar acción proactiva.

La combinación de Secure Boot + TPM 2.0 + VBS + Credential Guard + HVCI + BitLocker forma la pila completa de seguridad basada en hardware de Windows 11, donde cada capa depende de la anterior para construir un entorno de confianza desde el silicio hasta la aplicación.

11. PLATAFORMAS EDUCATIVAS

Las siguientes plataformas ofrecen entornos prácticos para aprender seguridad de Windows:

Plataforma	Recurso	Contenido
TryHackMe	Windows Fundamentals (Parts 1-3)	Navegación de GUI, sistema de archivos, permisos NTFS, servicios, registro, firewall
TryHackMe	Windows Privilege Escalation	Técnicas de escalación: tokens, servicios vulnerables, DLL hijacking, AlwaysInstallElevated
TryHackMe	Active Directory Basics	Estructura de AD, GPOs, Kerberos, LDAP, delegación
HackTheBox Academy	Windows Fundamentals (Tier 0)	Permisos NTFS/Share, servicios, WMI, registro, Event Viewer
HackTheBox Academy	Active Directory Enumeration	BloodHound, SharpHound, PowerView, enumeración de AD
Microsoft Learn	Security Baselines	Documentación oficial de baselines, GPO deployment, Intune
HardeningKitty	GitHub (código abierto)	PowerShell para auditar CIS/STIG/Microsoft Baselines automáticamente
CIS-CAT Lite	CIS SecureSuite	Escaneo gratuito contra benchmarks CIS seleccionados

12. DIEZ EJERCICIOS DE LA PRÁCTICA.

Los siguientes ejercicios están diseñados para sesiones de 2-3 horas usando máquinas virtuales Windows 11 Pro/Enterprise (versión 24H2 o 25H2), cubriendo el ciclo completo de hardening:

Laboratorio 1: Auditoría de Security Baseline con HardeningKitty

Descargar HardeningKitty desde GitHub. Ejecutar Invoke-HardeningKitty -Mode Audit -Log para auditar la máquina virtual contra el Microsoft Security Baseline. Registrar el puntaje inicial, identificar las 10 configuraciones más críticas que fallan, remediar al menos cinco de ellas editando Group Policy (gpedit.msc) o el registro, re-auditar y documentar la mejora del puntaje. Esto introduce a los estudiantes a la brecha de seguridad entre instalaciones por defecto y sistemas hardenizados.

Laboratorio 2: Configuración de Reglas ASR (Attack Surface Reduction)

Verificar que Microsoft Defender esté en modo activo (Get-MpComputerStatus). Habilitar las tres reglas de Standard Protection en modo Audit usando PowerShell: Add-MpPreference -AttackSurfaceReductionRules_Ids <GUID> -AttackSurfaceReductionRules_Actions AuditMode. Generar eventos simulados (ejecutar macro de Office, intentar acceso a LSASS con herramienta de prueba). Revisar eventos en Event Viewer (Event ID 1122 para Audit). Mover reglas a modo Block. Documentar el proceso y analizar qué comportamientos bloquea cada regla.

Laboratorio 3: Cifrado con BitLocker y Gestión de Claves

Verificar la presencia de TPM con tpm.msc y Get-Tpm. Habilitar BitLocker en la unidad del sistema vía manage-bde -on C: -RecoveryPassword. Verificar estado con manage-bde -status. Documentar la Recovery Key y entender dónde se respalda (AD DS/Entra ID/archivo/USB). Explorar las opciones de cifrado XTS-AES-128 vs XTS-AES-256 en Group Policy. Si el hardware lo soporta, verificar aceleración por hardware en el campo Encryption Method.

Laboratorio 4: Seguridad Basada en Virtualización (VBS y Credential Guard)

Ejecutar `msinfo32` y verificar el estado de: Virtualization Based Security, Credential Guard, HVCI (Memory Integrity). Navegar a Configuración > Seguridad del dispositivo > Aislamiento del núcleo para confirmar que Integridad de memoria está activa. Usar Device Guard PowerShell cmdlets: `Get-CimInstance -ClassName Win32_DeviceGuard -Namespace root\Microsoft\Windows\DeviceGuard`. Documentar cada componente VBS y explicar cómo protege contra ataques de robo de credenciales (Pass-the-Hash, Pass-the-Ticket).

Laboratorio 5: Windows Firewall con Seguridad Avanzada

Abrir `wf.msc` y revisar los tres perfiles de red (Domain, Private, Public). Documentar las reglas de entrada predeterminadas. Crear reglas personalizadas: bloquear todo el tráfico entrante en el perfil Public excepto HTTPS, permitir ping solo desde la subred local, bloquear un rango específico de IPs. Exportar configuración con `netsh advfirewall export backup.wfw`. Usar PowerShell: `New-NetFirewallRule -DisplayName 'Block Telnet' -Direction Inbound -LocalPort 23 -Protocol TCP -Action Block`. Verificar reglas con `Get-NetFirewallRule | Where-Object {$_.Enabled -eq 'True'}`.

Laboratorio 6: Políticas de Contraseñas, Bloqueo y Usuarios

Abrir `secpol.msc` (Local Security Policy). Configurar Account Policies: Password Policy (longitud mínima 14 caracteres, complejidad habilitada, historial de 24 contraseñas, edad máxima 365 días). Configurar Account Lockout Policy (umbral de 5 intentos, duración de 30 minutos). Crear una cuenta estándar para uso diario y verificar que la cuenta de administrador integrada esté renombrada y deshabilitada. Configurar User Rights Assignment: denegar inicio de sesión remoto a cuentas locales. Documentar cada política y su justificación de seguridad.

Laboratorio 7: Habilitación y Configuración de Sysmon Nativo

Verificar la versión de Windows (`winver` — requiere Build 26200.7922+). Habilitar Sysmon nativo: `Dism /Online /Enable-Feature /FeatureName:Sysmon`. Ejecutar Sysmon `-i` para iniciar con configuración por defecto. Descargar un archivo de configuración avanzado (ej: `SwiftOnSecurity/sysmon-config`) y aplicarlo con `Sysmon -c config.xml`. Generar actividad: crear un proceso PowerShell, conectar a un servidor remoto, crear un archivo en `%TEMP%`. Revisar los eventos en Event Viewer > Sysmon > Operational. Identificar Event IDs 1 (Process Create), 3 (Network Connection), 11 (File Create), y explicar cómo cada uno apoya la detección de amenazas.

Laboratorio 8: Controlled Folder Access y Simulación Anti-Ransomware

Habilitar Controlled Folder Access: `Set-MpPreference -EnableControlledFolderAccess Enabled`. Verificar carpetas protegidas por defecto (Documentos, Escritorio, Imágenes). Crear un script PowerShell simple que intente escribir en una carpeta protegida y observar el bloqueo. Agregar una aplicación confiable a la lista de permitidos: `Add-MpPreference -ControlledFolderAccessAllowedApplications 'C:\Program Files\MiApp\app.exe'`. Revisar eventos de bloqueo en Event Viewer (Event ID 1123). Documentar cómo esta funcionalidad protege contra ransomware que cifra archivos del usuario.

Laboratorio 9: Auditoría Avanzada de Eventos de Seguridad

Configurar Advanced Audit Policy vía Group Policy: habilitar éxito y fallo para Account Logon (Credential Validation), Logon/Logoff (Logon, Special Logon), Object Access (File System), Privilege Use (Sensitive Privilege Use), y Policy Change (Audit Policy Change). Generar eventos: iniciar sesión con credenciales inválidas, acceder a un archivo auditado, ejecutar un programa como administrador. Usar PowerShell para consultar: `Get-WinEvent -FilterHashtable @{LogName='Security'; Id=4625} | Select-Object -First 5` (inicios fallidos). Crear un filtro personalizado en Event Viewer para correlacionar eventos de seguridad.

Laboratorio 10: Windows Sandbox e Investigación de Software Sospechoso

Habilitar Windows Sandbox: `Dism /Online /Enable-Feature /FeatureName:"Containers-DisposableClientVM" /All`. Abrir Windows Sandbox desde el menú Inicio. Dentro del sandbox, descargar y ejecutar la herramienta EICAR test file (estándar de prueba antivirus). Observar la

detección de Defender dentro del sandbox. Verificar que al cerrar el sandbox, todo el contenido se elimina permanentemente. Crear un archivo de configuración .wsb personalizado que mapee una carpeta del host como solo lectura, habilite networking y configure un script de inicio. Documentar cómo Windows Sandbox proporciona un entorno desechable para análisis seguro de malware potencial.

RESUMÉN

El currículo modernizado debe centrarse en:

- Seguridad Basada en Virtualización (VBS) como fundamento arquitectónico de Windows 11
- Reglas ASR como la defensa proactiva que reemplaza al antivirus reactivo tradicional
- Sysmon nativo como herramienta estándar de detección de amenazas en endpoint
- BitLocker acelerado por hardware como la nueva frontera de cifrado de disco
- Smart App Control sin reinstalación como control de aplicaciones finalmente práctico
- Passkeys y Windows Hello como reemplazo de contraseñas vulnerables a phishing
- Certificados Secure Boot 2026 como acción urgente de mantenimiento de seguridad